

EX STUDIO • PASSWORDLESS AUTHENTICATION & PROFILE ONBOARDING

FRONTEND API SPECIFICATION & INTEGRATION MANUAL | CAPTURE • SHARE • DELIVER

Base URL: `http://<host>:8000/api/` • Auth: Bearer JWT / Cookies • Flow: Email → OTP → Auto-Register / Login → Step 3 of 3: Set Up Your Profile

1. COMPLETE USER AUTHENTICATION & PROFILE SETUP JOURNEY

This specification defines the frontend API integration contract for the EX Studio passwordless authentication pipeline and the **'Step 3 of 3: Set Up Your Profile'** onboarding screen.

- **Step 1 — User Enters Email:** Client calls `POST /api/auth/passwordless/reg/send-otp/` (for signup) or `/login/send-otp/` (for signin). Backend dispatches a 6-digit passcode (valid 10 min) and returns `is_registered`.
- **Step 2 — User Submits OTP:** Client calls `POST /api/auth/passwordless/reg/verify-otp/` or `/login/verify-otp/`. Sets secure HTTP-only cookies and returns user profile data.
- **Step 3 — Step 3 of 3: Set Up Your Profile:** Frontend renders the onboarding screen (*"Tell us a bit about yourself to personalize your studio workspace"*). Photographer fills: Profile Picture (optional upload or URL), Your Name (required), Phone Number (optional), and Occupation (optional).
- **Step 4 — Enter Workspace:** User clicks **'Enter Workspace' →**. Client dispatches `POST /api/photographers/onboarding/`. Backend updates profile, marks `is_onboarded = True`, `onboarding_step = 3`, and frontend redirects directly to dashboard.

2. REGISTRATION PASSWORDLESS ENDPOINTS (`/api/auth/passwordless/reg/`)

2.1 Send Registration OTP

Method: **POST** | Endpoint: `/api/auth/passwordless/reg/send-otp/` | Auth: None

Request Body (JSON):

```
{
  "email": "sarang@atelierstudio.com"
}
```

Response (200 OK):

```
{
  "status": "success",
  "message": "Verification code sent to your email for registration.",
  "email": "sarang@atelierstudio.com",
  "is_registered": false
}
```

2.2 Verify Registration OTP & Auto-Register

Method: **POST** | Endpoint: `/api/auth/passwordless/reg/verify-otp/` | Auth: None

Request Body (JSON):

```
{
  "email": "sarang@atelierstudio.com",
  "otp": "839201",
  "fullname": "Sarang Varma",      // Optional: Prefills user display name
  "role": "photographer"          // Optional: default "photographer"
}
```

Response (200 OK):

```
{
  "status": "success",
  "message": "Account registered and logged in successfully.",
  "is_new_user": true,
  "user": {
    "id": 12,
    "unique_id": "40a597a7-33e1-4c6e-b3f8-62d26f98c92a",
    "username": "sarang_varma",
    "email": "sarang@atelierstudio.com",
    "fullname": "Sarang Varma",
    "role": "photographer",
    "is_email_verified": true
  }
}
// Note: Tokens set in secure HTTP-only cookies (access_token & refresh_token)
```

2.3 Resend Registration OTP

Method: **POST** | Endpoint: `/api/auth/passwordless/reg/resend-otp/` | Auth: None

Request Body (JSON):

```
{
  "email": "sarang@atelierstudio.com"
}
```

Response (200 OK):

```
{
  "status": "success",
  "message": "A new verification code has been sent to your email.",
  "email": "sarang@atelierstudio.com",
  "is_registered": false
}
```

3. LOGIN PASSWORDLESS ENDPOINTS (/api/auth/passwordless/login/)

3.1 Send Login OTP

Method: **POST** | Endpoint: /api/auth/passwordless/login/send-otp/ | Auth: None

Request Body (JSON):

```
{
  "email": "sarang@atelierstudio.com"
}
```

Response (200 OK):

```
{
  "status": "success",
  "message": "Verification code sent to your email for login.",
  "email": "sarang@atelierstudio.com",
  "is_registered": true
}
```

3.2 Verify Login OTP & Authenticate

Method: **POST** | Endpoint: /api/auth/passwordless/login/verify-otp/ | Auth: None

Request Body (JSON):

```
{
  "email": "sarang@atelierstudio.com",
  "otp": "839201"
}
```

Response (200 OK):

```
{
  "status": "success",
  "message": "Login successful.",
  "is_new_user": false,
  "user": {
    "id": 12,
    "unique_id": "40a597a7-33e1-4c6e-b3f8-62d26f98c92a",
    "username": "sarang_varma",
    "email": "sarang@atelierstudio.com",
    "fullname": "Sarang Varma",
    "role": "photographer",
    "is_email_verified": true
  }
}
```

// Note: Tokens set in secure HTTP-only cookies (access_token & refresh_token)

3.3 Resend Login OTP

Method: **POST** | Endpoint: /api/auth/passwordless/login/resend-otp/ | Auth: None

Request Body (JSON):

```
{
  "email": "sarang@atelierstudio.com"
}
```

Response (200 OK):

```
{
  "status": "success",
  "message": "A new verification code has been sent to your email.",
  "email": "sarang@atelierstudio.com",
  "is_registered": true
}
```

4. CONVENIENCE SHORTHAND ALIASES (/api/auth/otp/)

Global aliases that automatically route between login and registration based on account state:

Action	Shorthand Endpoint	Target View & Behavior
Send OTP	POST /api/auth/otp/send/	Dispatches 6-digit passcode; returns is_registered.
Verify OTP	POST /api/auth/otp/verify/	Logs in existing user or auto-creates photographer profile.
Resend OTP	POST /api/auth/otp/resend/	Invalidates stale code and dispatches fresh passcode.

5. STEP 3 OF 3: SET UP YOUR PROFILE & ONBOARDING API

Directly implements the EX Studio onboarding screen: 'Set Up Your Profile' ('Tell us a bit about yourself to personalize your studio workspace.').

UI Element on Screen	API Field Name	Type & Requirements	Screen Placeholder / Details
Profile Picture	avatar (or avatar_url)	File (≤5MB) or URL Optional / Not mandatory	Upload portrait or studio avatar (PNG, JPG, WEBP).
Your Name	name	String • Required	Placeholder: e.g. Sarang Varma. Updates user & profile.
Phone Number (optional)	phone	String • Optional	Placeholder: +1 (555) 000-0000.
Occupation	occupation	String • Optional	Placeholder: e.g. Wedding Photographer.
Enter Workspace →	onboarding_step	Integer (default: 3)	Submit action → sets is_onboarded=True and enters workspace.

5.1 Inspect Current Onboarding State (GET)

Method: **GET** | Endpoint: /api/photographers/onboarding/ | Auth: Bearer Token

Response (200 OK):

```
{
  "status": "success",
  "is_onboarded": false,
  "onboarding_step": 1,
  "name": "Sarang Varma",
  "phone": "",
  "occupation": "",
  "avatar_url": ""
}
```

5.2 Submit Profile Setup & Complete Onboarding (POST)

Method: **POST** | Endpoints: /api/photographers/onboarding/ or /api/photographers/onboarding/complete/

Auth: Bearer Token (Photographer) | Content-Types: application/json or multipart/form-data

Option A: JSON Payload (Without Custom Image File):

```
{
  "name": "Sarang Varma",
  "phone": "+1 (555) 000-0000",
  "occupation": "Wedding Photographer",
  "onboarding_step": 3
}
```

Option B: Multipart/Form-Data Payload (With Profile Picture File):

Content-Type: multipart/form-data

```
name: "Sarang Varma"
phone: "+1 (555) 000-0000"
occupation: "Wedding Photographer"
avatar: <binary image file (PNG/JPG/WEBP up to 5MB)>
onboarding_step: 3
```

Response (200 OK — Transitions User into Workspace):

```
{
  "status": "success",
  "message": "Profile setup and onboarding completed successfully.",
  "is_onboarded": true,
  "onboarding_step": 3,
  "profile": {
    "id": 1,
    "name": "Sarang Varma",
    "phone": "+1 (555) 000-0000",
    "occupation": "Wedding Photographer",
    "avatar_url": "http://api.domain.com/media/photographer_profiles/avatar.jpg",
    "is_onboarded": true,
    "onboarding_step": 3,
    "storage_used_bytes": 0,
    "storage_limit_bytes": 128849018880
  },
  "user": {
    "id": 12,
    "username": "sarang_varma",
    "email": "sarang@atelierstudio.com",
    "fullname": "Sarang Varma",
    "phone": "+1 (555) 000-0000"
  }
}
```

6. FRONTEND (REACT 19 / VITE) INTEGRATION BEST PRACTICES

- **HTTP-Only Cookie Auth:** Auth tokens (access_token & refresh_token) are set as secure HTTP-only cookies on /verify-otp/. Enable credentials: 'include' in Axios / Fetch so cookies are transmitted automatically.
- **Auth Header:** If using custom token headers, pass Authorization: Bearer <access_token> with authenticated requests.
- **Route Protection:** Check profile.is_onboarded. If false, redirect to /onboarding; upon clicking 'Enter Workspace →', redirect to /dashboard.
- **Rate Limits & Validity:** OTP endpoints enforce a 60 req/min throttle. Passcodes expire after 10 minutes.